SBOM/SCA Security Scan Report

Software Bill of Materials & Supply Chain Security Analysis



Generated on December 23, 2025 at 12:28 PM

Executive Summary

Metric	Value
Total Vulnerabilities	16
Unique Packages Affected	7
Fixable Vulnerabilities	9
Average Risk Score	0.1393

Vulnerabilities by Severity

Severity	Count
HIGH	13
MEDIUM	3

Vulnerabilities by Fix Status

Fix Status	Count
Fixed	9
Not Fixed	7

Vulnerability #1: GHSA-wj6h-64fc-37mp

Property	Value
Vulnerability ID	GHSA-wj6h-64fc-37mp
Severity	HIGH
Risk Score	0.4634
CVSS Score	7.4
EPSS Score	0.0062
Fix Status	Not Fixed
Package	ecdsa@0.19.1
Type/Language	python/python
File Location	\uv.lock
CWE IDs	CWE-203, CWE-208, CWE-385
CVE IDs	CVE-2024-23342

Description

Minerva timing attack on P-256 in python-ecdsa

CVSS Details

Type: Secondary | **Version:** 3.1 | **Base Score:** 7.4
Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

EPSS Details

EPSS: 0.0062 | **Percentile:** 0.6944 | **Date:** 2025-12-21

Fix Information

Status: Not Fixed
No fixed versions available.

Package Details

Name: ecdsa
Version: 0.19.1
Type: python
Language: python
PURL: pkg:pypi/ecdsa@0.19.1

References

• https://github.com/tlsfuzzer/python-ecdsa/blob/master/SECURITY.md

• https://github.com/tlsfuzzer/python-ecdsa/security/advisories/GHSA-wj6h-64fc-37mp

• https://minerva.crocs.fi.muni.cz/

• https://securitypitfalls.wordpress.com/2018/08/03/constant-time-compare-in-python/

Vulnerability #2: GHSA-wj6h-64fc-37mp

Property	Value
Vulnerability ID	GHSA-wj6h-64fc-37mp
Severity	HIGH
Risk Score	0.4634
CVSS Score	7.4
EPSS Score	0.0062
Fix Status	Not Fixed
Package	ecdsa@0.19.1
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-203, CWE-208, CWE-385
CVE IDs	CVE-2024-23342

Description

Minerva timing attack on P-256 in python-ecdsa

CVSS Details

Type: Secondary | **Version:** 3.1 | **Base Score:** 7.4
Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

EPSS Details

EPSS: 0.0062 | **Percentile:** 0.6944 | **Date:** 2025-12-21

Fix Information

Status: Not Fixed
No fixed versions available.

Package Details

Name: ecdsa
Version: 0.19.1
Type: python
Language: python
PURL: pkg:pypi/ecdsa@0.19.1

References

• https://github.com/tlsfuzzer/python-ecdsa/blob/master/SECURITY.md

• https://github.com/tlsfuzzer/python-ecdsa/security/advisories/GHSA-wj6h-64fc-37mp

• https://minerva.crocs.fi.muni.cz/

• https://securitypitfalls.wordpress.com/2018/08/03/constant-time-compare-in-python/

Vulnerability #3: GHSA-7f5h-v6xp-fcq8

Property	Value
Vulnerability ID	GHSA-7f5h-v6xp-fcq8
Severity	HIGH
Risk Score	0.4403
CVSS Score	7.5
EPSS Score	0.0059
Fix Status	Fixed
Package	starlette@0.48.0
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-407
CVE IDs	CVE-2025-62727

Description

Starlette vulnerable to O(n^2) DoS via Range header merging in ``starlette.responses.FileResponse``

CVSS Details

Type: Secondary | **Version:** 3.1 | **Base Score:** 7.5
Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

EPSS Details

EPSS: 0.0059 | **Percentile:** 0.6841 | **Date:** 2025-12-21

Fix Information

Status: Fixed
Fixed Versions: 0.49.1

Package Details

Name: starlette
Version: 0.48.0
Type: python
Language: python
PURL: pkg:pypi/starlette@0.48.0

References

• https://github.com/Kludex/starlette/commit/4ea6e22b489ec388d6004cfbca52dd5b147127c5

• https://github.com/Kludex/starlette/commit/69ed26a85956ef4bd0161807eb27abf49be7cd3c

• https://github.com/Kludex/starlette/releases/tag/0.49.1

• https://github.com/Kludex/starlette/security/advisories/GHSA-7f5h-v6xp-fcq8

Vulnerability #4: GHSA-77cj-rv5x-v6r2

Property	Value
Vulnerability ID	GHSA-77cj-rv5x-v6r2
Severity	MEDIUM
Risk Score	0.3541
CVSS Score	6.1
EPSS Score	0.0064
Fix Status	Not Fixed
Package	fschat@0.2.36
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-601
CVE IDs	CVE-2024-10908

Description

FastChat open redirect vulnerability

CVSS Details

Type: Secondary | **Version:** 3.0 | **Base Score:** 6.1
Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

EPSS Details

EPSS: 0.0064 | **Percentile:** 0.6985 | **Date:** 2025-12-21

Fix Information

Status: Not Fixed
No fixed versions available.

Package Details

Name: fschat
Version: 0.2.36
Type: python
Language: python
PURL: pkg:pypi/fschat@0.2.36

References

• https://huntr.com/bounties/61f5e725-5579-4d08-8a88-e4ba04e6d1f2

Vulnerability #5: GHSA-79rp-v9rm-gxm8

Property	Value
Vulnerability ID	GHSA-79rp-v9rm-gxm8
Severity	HIGH
Risk Score	0.1807
CVSS Score	7.5
EPSS Score	0.0024
Fix Status	Not Fixed
Package	fschat@0.2.36
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-400
CVE IDs	CVE-2024-10912

Description

FastChat Denial of Service vulnerability

CVSS Details

Type: Secondary | **Version:** 3.0 | **Base Score:** 7.5
Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

EPSS Details

EPSS: 0.0024 | **Percentile:** 0.4729 | **Date:** 2025-12-21

Fix Information

Status: Not Fixed
No fixed versions available.

Package Details

Name: fschat
Version: 0.2.36
Type: python
Language: python
PURL: pkg:pypi/fschat@0.2.36

References

• https://huntr.com/bounties/52f335b8-1134-4d0f-acb4-efef516de414

Vulnerability #6: GHSA-h254-g997-685c

Property	Value
Vulnerability ID	GHSA-h254-g997-685c
Severity	HIGH
Risk Score	0.0915
CVSS Score	7.5
EPSS Score	0.0012
Fix Status	Not Fixed
Package	fschat@0.2.36
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-918
CVE IDs	CVE-2024-11603

Description

FastChat Server-Side Request Forgery vulnerability

CVSS Details

Type: Secondary | **Version:** 3.0 | **Base Score:** 7.5
Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

EPSS Details

EPSS: 0.0012 | **Percentile:** 0.3210 | **Date:** 2025-12-21

Fix Information

Status: Not Fixed
No fixed versions available.

Package Details

Name: fschat
Version: 0.2.36
Type: python
Language: python
PURL: pkg:pypi/fschat@0.2.36

References

• https://huntr.com/bounties/89f1158d-4a75-4000-a1bd-f82dd1a62bff

Vulnerability #7: GHSA-g44m-hpf4-vmrp

Property	Value
Vulnerability ID	GHSA-g44m-hpf4-vmrp
Severity	HIGH
Risk Score	0.0765
CVSS Score	7.5
EPSS Score	0.0010
Fix Status	Not Fixed
Package	fschat@0.2.36
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-918
CVE IDs	CVE-2024-12376

Description

FastChat Server-Side Request Forgery vulnerability

CVSS Details

Type: Secondary | **Version:** 3.0 | **Base Score:** 7.5
Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

EPSS Details

EPSS: 0.0010 | **Percentile:** 0.2881 | **Date:** 2025-12-21

Fix Information

Status: Not Fixed
No fixed versions available.

Package Details

Name: fschat
Version: 0.2.36
Type: python
Language: python
PURL: pkg:pypi/fschat@0.2.36

References

• https://huntr.com/bounties/c9cc3f28-ee9f-4d2d-9ee5-8c6455a11892

Vulnerability #8: GHSA-qg86-f892-m4hj

Property	Value
Vulnerability ID	GHSA-qg86-f892-m4hj
Severity	HIGH
Risk Score	0.0517
CVSS Score	7.5
EPSS Score	0.0007
Fix Status	Not Fixed
Package	fschat@0.2.36
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-835
CVE IDs	CVE-2024-10907

Description

FastChat Uncontrolled Resource Consumption vulnerability

CVSS Details

Type: Secondary | **Version:** 3.0 | **Base Score:** 7.5
Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

EPSS Details

EPSS: 0.0007 | **Percentile:** 0.2141 | **Date:** 2025-12-21

Fix Information

Status: Not Fixed
No fixed versions available.

Package Details

Name: fschat
Version: 0.2.36
Type: python
Language: python
PURL: pkg:pypi/fschat@0.2.36

References

• https://huntr.com/bounties/bf3ca81d-3508-4455-95d9-0b653e46d6e4

Vulnerability #9: GHSA-6qv9-48xg-fc7f

Property	Value
Vulnerability ID	GHSA-6qv9-48xg-fc7f
Severity	HIGH
Risk Score	0.0443
CVSS Score	N/A
EPSS Score	0.0006
Fix Status	Fixed
Package	langchain-core@0.3.78
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-1336
CVE IDs	CVE-2025-65106

Description

LangChain Vulnerable to Template Injection via Attribute Access in Prompt Templates

EPSS Details

EPSS: 0.0006 | **Percentile:** 0.1851 | **Date:** 2025-12-21

Fix Information

Status: Fixed
Fixed Versions: 0.3.80

Package Details

Name: langchain-core
Version: 0.3.78
Type: python
Language: python
PURL: pkg:pypi/langchain-core@0.3.78

References

• https://github.com/langchain-ai/langchain/commit/c4b6ba254e1a49ed91f2e268e6484011c540542a

• https://github.com/langchain-ai/langchain/commit/fa7789d6c21222b85211755d822ef698d3b34e00

• https://github.com/langchain-ai/langchain/security/advisories/GHSA-6qv9-48xg-fc7f

Vulnerability #10: GHSA-2xpw-w6gg-jr37

Property	Value
Vulnerability ID	GHSA-2xpw-w6gg-jr37
Severity	HIGH
Risk Score	0.0135
CVSS Score	N/A
EPSS Score	0.0002
Fix Status	Fixed
Package	urllib3@2.5.0
Type/Language	python/python
File Location	\uv.lock
CWE IDs	CWE-409
CVE IDs	CVE-2025-66471

Description

urllib3 streaming API improperly handles highly compressed data

EPSS Details

EPSS: 0.0002 | **Percentile:** 0.0377 | **Date:** 2025-12-21

Fix Information

Status: Fixed
Fixed Versions: 2.6.0

Package Details

Name: urllib3
Version: 2.5.0
Type: python
Language: python
PURL: pkg:pypi/urllib3@2.5.0

References

• https://github.com/urllib3/urllib3/commit/c19571de34c47de3a766541b041637ba5f716ed7

• https://github.com/urllib3/urllib3/security/advisories/GHSA-2xpw-w6gg-jr37

Vulnerability #11: GHSA-2xpw-w6gg-jr37

Property	Value
Vulnerability ID	GHSA-2xpw-w6gg-jr37
Severity	HIGH
Risk Score	0.0135
CVSS Score	N/A
EPSS Score	0.0002
Fix Status	Fixed
Package	urllib3@2.5.0
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-409
CVE IDs	CVE-2025-66471

Description

urllib3 streaming API improperly handles highly compressed data

EPSS Details

EPSS: 0.0002 | **Percentile:** 0.0377 | **Date:** 2025-12-21

Fix Information

Status: Fixed
Fixed Versions: 2.6.0

Package Details

Name: urllib3
Version: 2.5.0
Type: python
Language: python
PURL: pkg:pypi/urllib3@2.5.0

References

• https://github.com/urllib3/urllib3/commit/c19571de34c47de3a766541b041637ba5f716ed7

• https://github.com/urllib3/urllib3/security/advisories/GHSA-2xpw-w6gg-jr37

Vulnerability #12: GHSA-gm62-xv2j-4w53

Property	Value
Vulnerability ID	GHSA-gm62-xv2j-4w53
Severity	HIGH
Risk Score	0.0135
CVSS Score	N/A
EPSS Score	0.0002
Fix Status	Fixed
Package	urllib3@2.5.0
Type/Language	python/python
File Location	\uv.lock
CWE IDs	CWE-770
CVE IDs	CVE-2025-66418

Description

urllib3 allows an unbounded number of links in the decompression chain

EPSS Details

EPSS: 0.0002 | **Percentile:** 0.0377 | **Date:** 2025-12-21

Fix Information

Status: Fixed
Fixed Versions: 2.6.0

Package Details

Name: urllib3
Version: 2.5.0
Type: python
Language: python
PURL: pkg:pypi/urllib3@2.5.0

References

• https://github.com/urllib3/urllib3/commit/24d7b67eac89f94e11003424bcf0d8f7b72222a8

• https://github.com/urllib3/urllib3/security/advisories/GHSA-gm62-xv2j-4w53

Vulnerability #13: GHSA-gm62-xv2j-4w53

Property	Value
Vulnerability ID	GHSA-gm62-xv2j-4w53
Severity	HIGH
Risk Score	0.0135
CVSS Score	N/A
EPSS Score	0.0002
Fix Status	Fixed
Package	urllib3@2.5.0
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-770
CVE IDs	CVE-2025-66418

Description

urllib3 allows an unbounded number of links in the decompression chain

EPSS Details

EPSS: 0.0002 | **Percentile:** 0.0377 | **Date:** 2025-12-21

Fix Information

Status: Fixed
Fixed Versions: 2.6.0

Package Details

Name: urllib3
Version: 2.5.0
Type: python
Language: python
PURL: pkg:pypi/urllib3@2.5.0

References

• https://github.com/urllib3/urllib3/commit/24d7b67eac89f94e11003424bcf0d8f7b72222a8

• https://github.com/urllib3/urllib3/security/advisories/GHSA-gm62-xv2j-4w53

Vulnerability #14: GHSA-w853-jp5j-5j7f

Property	Value
Vulnerability ID	GHSA-w853-jp5j-5j7f
Severity	MEDIUM
Risk Score	0.0085
CVSS Score	6.3
EPSS Score	0.0001
Fix Status	Fixed
Package	filelock@3.19.1
Type/Language	python/python
File Location	\backend\uv.lock
CWE IDs	CWE-59, CWE-362, CWE-367
CVE IDs	CVE-2025-68146

Description

filelock has a TOCTOU race condition which allows symlink attacks during lock file creation

CVSS Details

Type: Secondary | **Version:** 3.1 | **Base Score:** 6.3
Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:N/I:H/A:H

EPSS Details

EPSS: 0.0001 | **Percentile:** 0.0215 | **Date:** 2025-12-21

Fix Information

Status: Fixed
Fixed Versions: 3.20.1

Package Details

Name: filelock
Version: 3.19.1
Type: python
Language: python
PURL: pkg:pypi/filelock@3.19.1

References

• https://github.com/tox-dev/filelock/commit/4724d7f8c3393ec1f048c93933e6e3e6ec321f0e

• https://github.com/tox-dev/filelock/pull/461

• https://github.com/tox-dev/filelock/releases/tag/3.20.1

• https://github.com/tox-dev/filelock/security/advisories/GHSA-w853-jp5j-5j7f

Vulnerability #15: GHSA-mwv6-3258-q52c

Property	Value
Vulnerability ID	GHSA-mwv6-3258-q52c
Severity	HIGH
Risk Score	0.0000
CVSS Score	7.5
EPSS Score	N/A
Fix Status	Fixed
Package	next@15.4.8
Type/Language	npm/javascript
File Location	\frontend\package-lock.json

Description

Next Vulnerable to Denial of Service with Server Components

CVSS Details

Type: Secondary | **Version:** 3.1 | **Base Score:** 7.5
Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Fix Information

Status: Fixed
Fixed Versions: 15.4.9

Package Details

Name: next
Version: 15.4.8
Type: npm
Language: javascript
PURL: pkg:npm/next@15.4.8

Vulnerability #16: GHSA-w37m-7fhw-fmv9

Property	Value
Vulnerability ID	GHSA-w37m-7fhw-fmv9
Severity	MEDIUM
Risk Score	0.0000
CVSS Score	5.3
EPSS Score	N/A
Fix Status	Fixed
Package	next@15.4.8
Type/Language	npm/javascript
File Location	\frontend\package-lock.json

Description

Next Server Actions Source Code Exposure

CVSS Details

Type: Secondary | **Version:** 3.1 | **Base Score:** 5.3
Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Fix Information

Status: Fixed
Fixed Versions: 15.4.9

Package Details

Name: next
Version: 15.4.8
Type: npm
Language: javascript
PURL: pkg:npm/next@15.4.8